

DFIR Investigation Lifecycle & Technical Notes

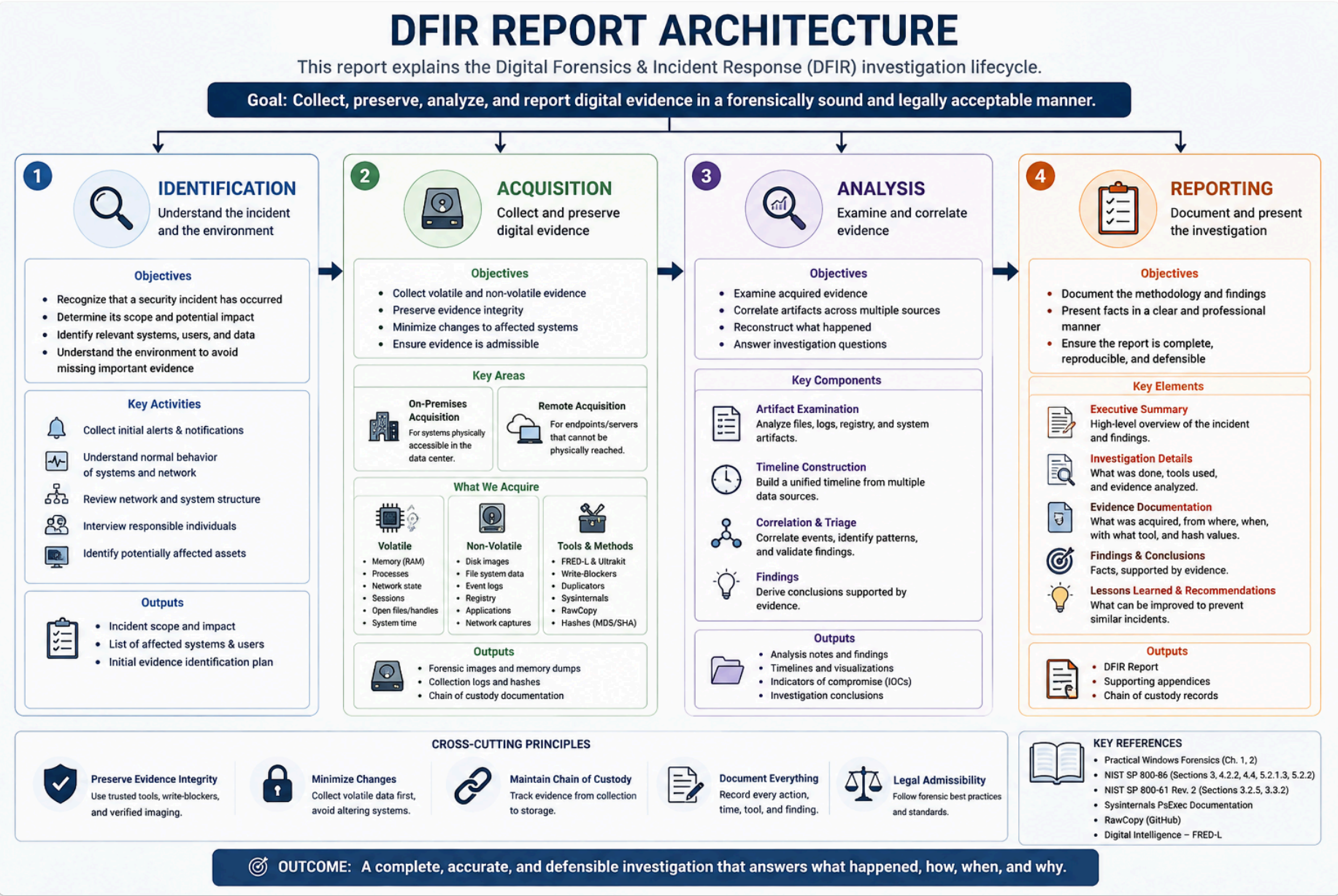
Generally, **forensic science** is the scientific method of gathering and examining data about the past to extract useful information related to the case under investigation.

Digital forensics is the analysis of digital evidence in order to answer questions related to a digital incident, which takes place at the time of the analysis in case of a live analysis or takes place in the past; this is called **postmortem analysis**. Postmortem analysis is applied after the incident has occurred, and it usually takes place in all cases. However, some cases require the analysis to be conducted during the incident.

So, Identifying and analyzing information security incidents and the related digital evidence is called **digital forensics**.

One of the definitions of digital forensics is **Rodney McKemmish's**, which stated the following:

“Forensic Computing is the process of identifying, preserving, analyzing, and presenting digital evidence in a manner that is legally acceptable.”



Phases

1. Identification
2. Acquisition
3. Analysis
4. Reporting

Identification

The investigator or the analyst must understand the circumstances of the incident and collect the data that is important to the investigation.

They need to understand:

- the usual behavior of the systems
- the structure of the network
- they need to interview responsible individuals if needed.

Identification phase is the process of recognizing that a security incident has occurred, determining its scope and potential impact, and identifying the systems, users, and digital evidence relevant to the investigation before evidence collection begins. The investigator first understands the environment to ensure important evidence is not overlooked.

Acquisition

FRED-L is a portable forensic workstation designed to perform digital evidence acquisition and analysis in a forensically sound environment. It enables investigators to create forensic images, analyze digital media, and preserve evidence integrity during incident response and forensic investigations.

Note: FRED-L is not a forensic tool itself; it is a specialized forensic platform that integrates hardware and software to support evidence acquisition, preservation, and forensic analysis while maintaining forensic best practices.



Components:

- High RAM/CPU specs to handle memory dumps, disk imaging, and RAID reconstruction on-site
- Multiple write-blocked bays / interfaces (SATA, IDE, USB, NVMe) built in
- Pre-loaded forensic suite: imaging tools (FTK Imager, dd/dcfldd), memory acquisition tools (WinPmem, Magnet RAM Capture), hashing utilities, triage scripts (KAPE, Velociraptor)

For more details: [Digital Intelligence](#)

Ultrakit

The physical hardware complement to FREDL, everything needed to connect to and safely extract data from whatever storage media you find on-site.

Components:

- Hardware **write blockers** (SATA/IDE/USB/NVMe) — non-negotiable for evidence integrity
- Assorted cables & adapters (SATA, mSATA, M.2, IDE, USB-C, Thunderbolt)
- External drive docks / bays for imaging target disks
- Forensic-wiped storage drives to receive images
- Basic toolkit (screwdrivers, anti-static wrist strap, torch) to physically open and access devices
- Evidence bags, tamper-evident seals, and chain-of-custody forms

For more details: [Digital Intelligence](#)

Duplicator

It's a dedicated hardware device that creates a **bit-for-bit (forensic) copy** of a storage device while preserving every sector, including deleted data and unallocated space. Unlike standard file copying, duplicators acquire the entire media, ensuring the forensic image is an exact replica of the original evidence.

The duplicator reads the source drive at the **sector level** and writes an identical copy to a destination drive or forensic image file. During acquisition, it calculates cryptographic hash values (e.g., **MD5**, **SHA-1**, or **SHA-256**) before and/or after imaging to verify that the copied evidence is identical to the original.

for more details: [Digital Intelligence](#)

Write-Blockers

A write blocker is a hardware or software mechanism that **prevents any write operation** from reaching the source storage device during forensic acquisition. This ensures the original evidence remains unchanged and maintains its forensic integrity.

A write blocker is placed **between the forensic workstation and the evidence drive**. It intercepts storage commands at the interface level, allowing all **read requests** to pass while blocking or rejecting any **write commands** issued by the operating system or forensic software.

This protects the evidence from accidental modification, such as metadata updates or file system changes.

- **Read commands** (e.g., `READ DMA`, `READ SECTOR`) are forwarded normally.

- **Write or modify commands** (e.g., `WRITE` , `FORMAT` , `TRIM` , metadata updates) are intercepted and blocked before reaching the evidence drive.

 How Write Blocker blocks any modifications commands during acquisition

During forensic acquisition, the forensic workstation reads disk sectors without modifying the evidence. However, a typical operating system may attempt to update file system metadata, such as access timestamps, journal records, or mount information, as a result of accessing the drive.

A write blocker intercepts these write commands before they reach the evidence disk, ensuring that only read operations are performed and the original media remains unchanged.

In a typical on-premises acquisition, a **write blocker** first protects the evidence drive from modification, while a **forensic duplicator** then creates a verified forensic image of that protected drive. Together, they ensure the acquisition process preserves evidence integrity and maintains forensic soundness.

To summarize, responders need to include the following items in a basic set:

- Several network cables (straight through or loopback)
- A serial cable with a serial USB adapter
- Network serial adapters
- Hard drives (various sizes)
- Flash drives
- A Linux Live DVD
- A portable drive duplicator with a write-blocker
- Various drive interface adapters
- A four port hub
- A digital camera
- Cable ties
- Cable snips
- Assorted screws and hex drivers
- Notebooks and pens
- Chain of Custody forms
- Incident handling procedure

Remotely

At the same time, several affected systems were located in remote branch offices where physical access was unavailable. To avoid delaying the investigation, responders initiated remote live acquisition to collect volatile evidence before full forensic imaging could be scheduled.

*Remote acquisition relies on trusted administrative and forensic utilities to collect evidence from systems that are not physically accessible. Among the most widely used tools is the **Sysinternals Suite**, particularly **Psexec**, which enables responders to execute commands remotely and acquire volatile forensic artifacts.*

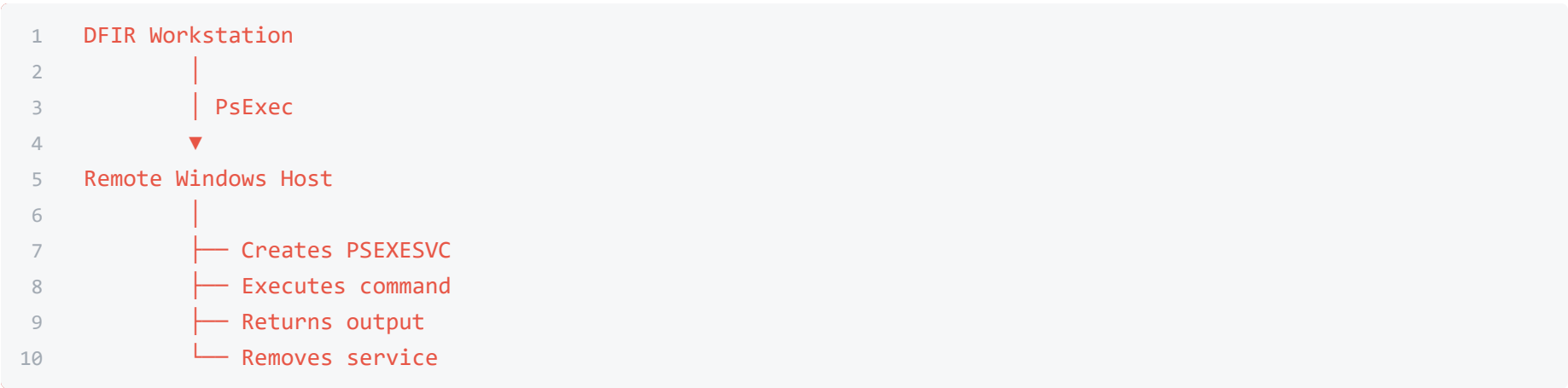
Sysinternals Suit - PsExec Utility

The Sysinternals Suite is a collection of Microsoft Windows utilities used for advanced system administration, troubleshooting, and forensic investigations.

In DFIR, responders commonly use these tools during **remote live acquisition** to collect volatile artifacts, inspect system state, and execute trusted commands on remote Windows hosts without requiring physical access.

Among the suite, **Psexec** is one of the most widely used utilities because it enables responders to remotely execute commands and forensic collection scripts under administrative privileges.

How PsExec Works



- Before executing the command, PsExec unpacks this hidden resource in the administrative sphere of the remote computer at Admin\$ (C:\Windows) file Admin\$\system32\psexecsvc.exe
- After copying this, PsExec installs and runs the service using the API functions of the Windows management services.
- Then, after starting psexesvc, a data connection (input commands and getting results) between psexesvc and psexec is established.
- Upon completion of the work, psexec stops the service and removes it from the target computer.

Practical example

Suppose responders need to identify suspicious network activity on a compromised server before shutting it down.

```
1 psexec \\FIN-SRV-01 cmd.exe
```

After obtaining a remote shell, responders can collect volatile evidence:

```
1 tasklist /v
2 netstat -ano
3 ipconfig /all
4 systeminfo
5 whoami
```

The collected artifacts can then be redirected to files and transferred for later forensic analysis.

*PsExec is extremely valuable for remote acquisition, but it is **not forensically transparent**. Because it creates a temporary service and executes commands on the target system, it inevitably changes system state. This behavior introduces the **Observer Effect**, making it essential to document every action performed during acquisition and understand its impact on the evidence.*

there are some issues/problems/limitations

Observer Effect

The Observer Effect refers to the unavoidable changes made to a live system while collecting forensic evidence. Simply executing commands or forensic utilities may modify memory, create processes, update logs, or alter timestamps, resulting in changes to the original system state.

So, How to limit this effect:

- Follow a predefined acquisition procedure.
- Record every command and action performed during acquisition in the Final Report.
- Acquire the most volatile evidence first (Order of Volatility).

Locked File Access

Some critical forensic artifacts are locked by the Windows operating system while it is running. Files such as Registry hives, the MFT, and other system files cannot be copied using standard file copy operations because they are actively in use.

So, How to resolve this issue!

Specialized forensic utilities can access these locked files using low-level disk reading techniques instead of normal Windows file APIs. One of the most common tools for this purpose is **RawCopy.exe**.

RawCopy mechanism

RawCopy is a forensic acquisition utility that copies locked NTFS files directly from the disk by performing **low-level raw disk reads**, bypassing the normal Windows file access mechanisms. Instead of requesting the operating system to open the file, which would fail if the file is locked, RawCopy reads the file's underlying **NTFS data structures** directly from the storage device. This allows responders to acquire artifacts such as **SYSTEM**, **SAM**, **SECURITY**, **SOFTWARE**, the **\$MFT**, and files inside **System Volume Information** while Windows is still running.

Suppose as an example scenario, responders need to acquire the **SYSTEM** Registry hive from a live Windows machine before shutting it down. Since the file is locked by the operating system, a normal copy operation would fail.

Using RawCopy:

```
1 RawCopy.exe C:\Windows\System32\Config\SYSTEM C:\Evidence\
```

RawCopy reads the Registry hive directly from the NTFS volume and stores a forensic copy in the specified evidence directory without relying on the standard Windows file access APIs.

If the remote collection of information is necessary, a working machine running UNIX OS can use the Winexe utility.

Winexe is a GNU/Linux-based application that allows users to execute commands remotely on WindowsNT/2000/XP/2003/Vista/7/8 systems. It installs a service on the remote system, executes the command, and uninstalls the service.

Winexe allows execution of most of the Windows shell commands:

```
1 winexe -U [Domain/]User%Password //host command
```

To launch a Windows shell from inside your Linux system, use the following command:

```
1 winexe -U HOME/Administrator%Pass123 //192.168.0.1 "cmd.exe"
```

Analysis

The Analysis phase is the process of examining and correlating the collected digital evidence to reconstruct the incident, determine what occurred, identify the attacker's actions and techniques, and answer key investigative questions such as **how**, **when**, and **what impact** the incident had. The analyst evaluates all available evidence to build an accurate timeline and reach evidence-based conclusions.

Analysis Approaches

There are two general approaches that can be used to deal with a security incident:

- Live Analysis
- Postmortem Analysis

Live Analysis (Power-on)

This is usually performed when the analyst has a live system in hand. This can provide valuable information that can guide the analyst in the future investigation.

Postmortem Analysis (Dead-box)

This is the normal steps of the process, where the responder acquires all the available data from the incident scene, and then conducts postmortem analysis on the evidence.

Hybrid Analysis

where the responder conducts the live analysis on the powered on and accessible systems, records their findings, and acquires all the data, including the live ones, for postmortem analysis.

Evidence (Data) Categories

- Volatile Evidence
- Non-Volatile Evidence

Volatile Evidence

Under the principle of “order of Volatility”, you must first collect information that is classified as Volatile Data which will be irretrievably lost in case the computer is powered off.

Typically, this category includes the following data:

System Time

to establish a reliable temporal reference for correlating events and building the incident timeline.

```
1 (date / t) & (time / t)>%COMPUTER_NAME% \ systime.txt
2
3 systeminfo | find "Boot Time" >>% COMPUTERNAME% \ systime.txt
```

- `date /t / time /t` : retrieves the current system date and time.
- `systeminfo` : provides system information, including the system boot time.

Network State

to reveals active and recent network activity that may indicate Command & Control, lateral movement, or suspicious external communication.

```
1 nbtstat -c> %COMPUTERNAME%\NetNameCache.txt
```

```

2
3 netstat -a -n -o>%COMPUTERNAME%\NetStat.txt
4
5 netstat -rn>%COMPUTERNAME%\NetRoute.txt
6
7 ipconfig / all>%COMPUTERNAME%\NIC.txt
8
9 promqry>%COMPUTERNAME%\NSniff.txt

```

- nbtstat -c : displays the **NetBIOS name cache**.
- netstat -a -n -o : **shows connections**, listening ports, and associated process IDs.
- netstat -rn : displays the **routing table**.
- ipconfig /all : displays detailed network **interface configuration**.

Logged on users and active sessions

To identifies accounts currently or recently active on the system and helps determine whether unauthorized access or account abuse occurred.

```

1 psloggedon -x>%COMPUTERNAME% \ LoggedUsers.tx:
2
3 logonsessions -p >> %COMPUTERNAME%\LoggedOnUsers.txt

```

- psloggedon : identifies **locally** and **remotely** logged-on **users**.
- logonsessions : displays active **logon sessions** and **associated processes**.

Loaded Drivers

To identifies kernel-level components currently loaded into memory, which may reveal suspicious or malicious drivers.

```

1 drivers.exe>%COMPUTERNAME%\drivers.txt

```

- the **WDK** drivers.exe utility **lists loaded** Windows **drivers** and their associated information.

Running Services

to identify malicious or unauthorized services that may be used for execution or persistence.

```

1 psservice>%COMPUTERNAME% \ trasklst.txt

```

- psservice : **displays** and **manages** Windows **services**, including their current state.

Running Processes, DLLs & Handles

to provide visibility into active execution, loaded modules, and resources accessed by processes, helping identify suspicious processes, DLL injection, or abnormal activity.

```

1 tasklist / svc>%COMPUTERNAME% \ taskdserv.txt
2
3 tasklist / v>%COMPUTERNAME% \ taskuserinfo.txt
4
5 pslist / t>%COMPUTERNAME%\tasktree.txt
6
7 listdlls>%COMPUTERNAME%\lstdlls.txt
8
9 handle -a>%COMPUTERNAME%\lsthandles.txt

```

- tasklist /svc : maps running processes to their hosted services.
- tasklist /v : displays detailed information about running processes.
- pslist /t : displays processes in a hierarchical process tree.
- listdlls : lists DLLs loaded by running processes.
- handle -a : displays handles opened by processes.

Persistence & Lateral Movement Check

Identifies mechanisms that may allow an attacker to survive reboots or move between systems.

```

1 autorunsc.exe -a>%COMPUTERNAME% \ autoruns.txt
2
3 at>%COMPUTERNAME% \ at.txt

```

```
4
5 schtasks / query>%COMPUTERNAME% \ schtask.txt
```

- `autorunsc` utility: displays a list of **executables that run at system startup** and when users log on.
- Two other commands (`at` and `schtasks`) display a list of commands that run in the schedule.

Non-Volatile Evidence

Non-volatile data is digital evidence that remains stored after a system is powered off. Unlike volatile data, it is not lost when power is removed, allowing investigators to perform a detailed **postmortem analysis** using forensic images acquired during the acquisition phase. This evidence helps reconstruct the incident timeline, identify attacker activity, and determine the scope and impact of the compromise.

Evidence Sources for Postmortem Analysis

Non-volatile analysis may be performed on evidence obtained from:

- **Disk Images**
to complete forensic copies of storage devices.
- **Memory Dumps**
captured RAM preserved as an evidence file for later analysis.
- **PCAP Files**
captured network traffic preserved for offline network analysis.
- **File System Artifacts**
files, metadata, timestamps, and directory structures.
- **Windows Event Logs**
records of system, security, and application activity.
- **Registry Hives**
persistent configuration and user/system activity artifacts.
- **Application Artifacts**
evidence generated by browsers and other applications.
- **Persistence Artifacts**
scheduled tasks, services, startup locations, and related configurations.

The analyst correlates these artifacts to reconstruct:

- ****what happened?**
- **when it happened?**
- **how the attacker operated?**
- **what systems or data were affected**

Report

A professional DFIR report should clearly document the investigation process, the evidence examined, the findings reached, and the reasoning behind each conclusion, allowing other analysts to understand, verify, and reproduce the investigation where necessary.

How to document a professional report

- Separate facts from conclusions
- Every finding needs supporting evidence
- Build one coherent timeline
- Document acquisition properly
For each evidence item, record:
 - Host / source, What was acquired, Tool and version, Acquisition time, Hash. Evidence ID.
- Show your reasoning
- Document negative findings
- Make commands and queries reproducible
- Screenshots should support a finding
- Finally, the conclusion must answer the investigation
 - What happened? When? How?
 - Which systems/accounts were involved?
 - What was affected?
 - What evidence supports it?
 - What remains unknown?

References

Books

Shaaban, A., & Saprnov, K. (2016). *Practical Windows Forensics*

- Chapter 1 — *The Foundations and Principles of Digital Forensics*
- Chapter 2 — *Incident Response and Live Analysis*

Ayman Shaaban
Konstantin Saprnov

Standards & Guidelines

NIST SP 800-86 — Guide to Integrating Forensic Techniques into Incident Response
[SP 800-86, Guide to Integrating Forensic Techniques into Incident Response | CSRC](#)

- §3 — *Performing the Forensic Process* — Acquisition
- §3.1.2 — *Acquiring the Data* — Remote Acquisition
- §3.3 — *Analysis* — Analysis Phase
- §4.2.2 — *Data File Integrity* — Write-Blockers
- §4.4 — *Timeline Analysis* — Timeline Analysis
- §5.2.1.3 — *Prioritizing Data Collection* — Volatile Evidence & Order of Volatility
- §5.2.2 — *Collecting Non-Volatile OS Data* — Non-Volatile Evidence

NIST SP 800-61 Rev. 2 — Computer Security Incident Handling Guide (Referenced Edition)
[SP 800-61 Rev. 2, Computer Security Incident Handling Guide | CSRC](#)

- §3.2.5 — *Incident Documentation* — Reporting & separating facts from conclusions
- §3.3.2 — *Evidence Gathering and Handling* — Evidence acquisition and handling documentation

Technical Documentation

Microsoft Sysinternals — PsExec
[PsExec — Sysinternals | Microsoft Learn](#)

J. Schicht — RawCopy: Command-line low-level file extractor for NTFS
[RawCopy GitHub](#)

Digital Intelligence — FRED-L
[Digital Intelligence — FRED-L](#)